

Cybersecurity Compliance Manual — CII Owner

Pre-Amendment Baseline Version

Important scope note: This manual provides a baseline cybersecurity compliance framework for an organisation operating designated Critical Information Infrastructure (CII). It is deliberately written without incorporating the later amendments expanding the Cybersecurity Act framework to additional classes of regulated entities.

1. Purpose and Scope

- Establish minimum governance, operational and documentation practices for protecting designated CII.
- Define responsibilities for management, the CII owner, cybersecurity personnel, system owners and relevant service providers.
- Provide a repeatable framework for risk management, incident response, audits, testing and regulatory engagement.

2. Governance and Accountability

- Senior management should maintain oversight of cybersecurity risk affecting the CII.
- The CII owner should designate responsible personnel for cybersecurity governance and incident management.
- Roles and escalation responsibilities should be documented and reviewed periodically.
- Cybersecurity policies should be approved through the organisation's established governance process.

3. Cybersecurity Risk Management

- Maintain an inventory of CII assets, systems, interfaces and critical dependencies.
- Identify cybersecurity threats and vulnerabilities and assess their potential impact on essential services.
- Maintain a risk register and assign owners, mitigation measures and review dates.
- Reassess material risks following significant system, technology or operational changes.

4. Cybersecurity Policies and Procedures

- Maintain documented policies covering access control, authentication, asset management, vulnerability management, logging, monitoring, backup, business continuity and incident response.
- Policies should be accessible to relevant personnel and reviewed periodically.
- Material deviations from approved security procedures should be documented and escalated.

5. Access Control

- Apply least-privilege principles to administrative and privileged access.
- Review user and privileged accounts periodically.
- Remove or modify access promptly when personnel change roles or leave the organisation.
- Protect authentication credentials and implement stronger authentication controls where appropriate.

6. Vulnerability and Patch Management

- Maintain processes for identifying, assessing and remediating vulnerabilities.
- Prioritise remediation according to severity, exploitability and impact on CII.
- Document exceptions where vulnerabilities cannot be remediated within the expected timeframe.

7. Monitoring, Logging and Detection

- Maintain appropriate security monitoring for CII systems.
- Retain relevant logs for investigation and audit purposes.
- Establish escalation procedures for suspicious activity and suspected compromise.

8. Incident Response

- Maintain an incident response plan covering detection, triage, containment, eradication, recovery and post-incident review.
- Define internal escalation thresholds and responsibilities.
- Preserve relevant evidence and maintain an incident record.
- Assess incidents against applicable statutory and regulatory reporting requirements.

9. Business Continuity and Recovery

- Maintain backups and recovery procedures appropriate to the criticality of CII systems.
- Test recovery procedures periodically.
- Document recovery priorities, dependencies and responsible personnel.

10. Third-Party and Service Provider Management

- Assess cybersecurity risks arising from third-party access to or dependence on CII.
- Use contractual controls addressing security responsibilities, incident notification, access, confidentiality and cooperation.
- Monitor material third-party cybersecurity risks throughout the relationship.

11. Security Testing and Assurance

- Conduct periodic security assessments and testing appropriate to the CII environment.
- Track findings to remediation and document management acceptance of residual risk.
- Maintain evidence of assessments, tests and remediation activities.

12. Training and Awareness

- Provide cybersecurity awareness training to relevant personnel.
- Provide role-specific training for administrators, incident responders and personnel with privileged access.
- Maintain records of completed training.

13. Documentation and Records

- Maintain current copies of policies, procedures, risk assessments, incident records, test reports and relevant approvals.
- Version-control material cybersecurity documents.
- Ensure superseded versions are clearly identified and retained only where required for audit or historical purposes.

14. Periodic Review

- Review this manual at least annually and following material cybersecurity incidents, major system changes or relevant regulatory developments.

- Record the date, reviewer, changes made and approval status.

Document control

Version: 1.0

Status: Illustrative pre-amendment baseline

Owner: Legal / Compliance / Cybersecurity

Review cycle: Annual or upon material regulatory change